Target: OWASP Juice Shop

Method: (1) Identify Key assets, (2) List of potential threats, (3) Create a risk matrix, (4) Suggest mitigations for high-risk items.

Key assets

ID	Asset	Examples in Juice Shop
A1	User data	Names, Emails, addresses, security answers, etc.
A2	Payment Info	Saved cards, wallet balance, order totals, etc.
A3	Authentication tokens	Jwt in cookie, password hashes
A4	Admin functions	Admin panel, user management, feedback and product management
A5	Application files and config	/ftp directory, backups, uploads, etc.
A6	Service available	Shop front end, REST API, SQLite database

Threat list

ID	Threats
T1	SQL Injection
T2	Broken Authentication
T3	Cross-site scripting
T4	Broken Access Control
T5	Sensitive Data exposure
T6	Vulnerable components
T7	Security Misconfiguration
T8	SSRF
T9	Brute force
T10	Cross-site request forgery
T11	Malicious file upload
T12	Insufficient logging and monitoring

Risk Matrix

LIKELIHOOD						
	5				T3, T4, T5	T1
	4		T7	T9	T10	T2
	3		T12	T6, T11		
	2			T8		
	1					
		1	2	3	4	5
IMPACT						

Mitigation

ID	Threats	Score	Rating	Proposed mitigation
T1	SQL Injection	25	Critical	Parameterized queries / ORM bindings; server-side input validation; least-privilege DB account; generic error messages.
T2	Broken Authentication	20	Critical	Strong random signing secret, reject alg=none, short token expiry; remove default / guessable credentials; MFA for admin.
T3	Cross-site scripting	20	Critical	Context-aware output encoding; avoid innerHTML / bypassSecurityTrust; sanitise input; strict CSP; HttpOnly + Secure cookies.
T4	Broken Access Control	20	Critical	Server-side authorisation on every request; check object ownership; deny by default; unguessable IDs.
T5	Sensitive Data Exposure	20	Critical	Remove public file listings and backups; restrict /metrics; hash with bcrypt/argon2 + salt; enforce HTTPS and HSTS.
T10	Cross-site request forgery	16	High	Anti-CSRF tokens; SameSite=Lax/Strict cookies; require current password for change; use POST/PUT, never GET, for state changes.
T9	Brute Force	12	High	Rate limiting, account lockout / backoff, CAPTCHA, alerting on repeated failures.